

Introduction of Cyber Kill Chain

- Inspired by the military kill chains
- Cyber security framework by Lockheed Martin (2011)
- Created to help organizations defend against cyber-attacks by understanding how the attacks are realized
- We can stop the attack from stage 3
- If we stop it in any stage from 3, it doesn't continue anymore (that's the goal)
- Divided into 7 stages:
 - 1) Reconnaissance
 - 2) Weaponization
 - 3) Delivery
 - 4) Exploitation
 - 5) Installation
 - 6) Command and Control
 - 7) Actions on Objectives

Reconnaissance

Gathering information about a target (vulnerabilities and weaknesses to discover potential entry points)

2 types: passive and active

Passive Reconnaissance	Active Reconnaissance
acts without making any "noise" (using OSINT)	acts by interacting in some way with an organization/target (using social engineering against employees or scanning a target system for vulnerabilities – for example open ports (nmap))
Example: Social media reconnaissance, Google Dorking	Example: Network port scanning (identifying live hosts and running services) Attacker visiting target organization in person to identify entry points / study security measures and observe personnel behaviour

SOLUTION

- 1) Minimising public information (from public to private accounts, minimising WHOIS records – so they don't reveal names or addresses that are best left private)
- 2) Check service logs to uncover reconnaissance attempts

Weaponization

After gathering information about the target, an attacker needs to create a payload tailored to exploit the weaknesses discovered. Many attackers hide the payload in benign-looking file, such as MS Word or a PDF file. At the end of this stage, deliverable malicious file will be ready to be delivered to the target system. Attackers often use ways of obfuscation or encryption to evade detection.

Attackers might use one of the available exploit kits (for example from ExploitDB website). An exploit kit is an automated platform containing various exploits for various vulnerabilities. Then thanks to these platforms they know how to package the exploit code within a payload, such as executable file or document.

However, not all documents can be weaponized to carry exploit code.

Attackers often choose Microsoft Office documents with malicious macros. If macros are enabled, a macro executes a saved set of instructions when the document is opened.

SOLUTION

- 1) User training and have disabled all unnecessary features/software and remove unnecessary browser plugins. (create proper restrictions)

Delivery

After we have successfully crafted the malware / malicious payload, we need to be able to deliver it to the victim's workstation/device.

Type of delivery	Description
Phishing emails	Emails containing malicious attachments or use links for malicious downloads. File names play a significant role (invoice.pdf.exe)
Spear phishing emails	Targeted person in the organization (job application response – HR employee)
Malicious web links	Public websites with malware content / domain spoofing (microsoft.com > micr0soft.com)
File-sharing platforms	Attacker depends on the familiarity (for example downloading cracked game – boom it's a trojan)
Malvertising	Method involves showing ads on legitimate websites to redirect users to malicious pages
Smishing (SMS Phishing)	The attacker sends text messages with malicious links or instructions to download malware (connected to social engineering / impersonization)
Social engineering	Impersonation / Act of conviction (depending on naivety / trust / urgency)
Physical means of delivery	USB flash drive / DVD / hard disk

SOLUTION:

- 1) User training awareness (SAE in organizations)
- 2) WAFs (Web application firewalls) – responsible for blocking malicious files available via the web browser.

Exploitation

After successful delivery of the malicious payload (victims clicks on the attachment). Attackers might target a password-based authentication system (connected to phishing for tricking users into submitting their password), software vulnerabilities (zero-days exploits! = not yet discovered vulnerability by vendor, but already by an attacker), SQL injection, buffer overflow, etc...

SOLUTION:

- 1) Enhanced password requirements – MFA (Multi-Factor authentication)
- 2) Patch management + vulnerability scanning
- 3) Intrusion Prevention Systems (IPS) – for detections and blocking of potentially malicious traffic
- 4) Web Application Firewalls (WAPs) – can block attacks against web applications (SQL injection, cross-site scripting, cross-site request forgery)

Installation

After the exploitation of a target system, installation phase ensures persistent access to the exploited system. Installation is about setting foothold (persistence) in the system.

Persistence is usually created by scheduler tasks in the MS Windows or setting a cron job in Linux systems, so when the computer is restarted, the attacker has yet again access to the system. They often take advantage of legitimate processes/binaries already installed in the system to download another malware for enabling C2 communication (living-off-the-land binaries = LOLBins). These are often wget or curl commands or they set up web shell, which helps them execute OS commands on the target via a web browser interface.

SOLUTION:

- 1) Monitoring new processes and services
- 2) Endpoint Detection and Response (EDR) – allows monitoring endpoints for suspicious activities, such as unusual process creation, file modification in private/sensitive directories (/var or /System32)
- 3) Application allowlisting – which prevents the execution of unauthorized or malicious software by allowing only approved applications to run.

Command and Control (C2)

After successful installation of persistent access within the target environment, the attacker needs to maintain reliable and discreet access to the compromised system so that they can later act on their objectives. Attacker sets up the C2 communication channel between the compromised systems and attacker's machine.

For attackers it is possible to use DNS tunnelling (encoding data (base 64 for example) within DNS requests, to bypass various security solutions and firewalls)

SOLUTION:

- 1) Monitor network traffic for malicious IP address from known databases like (Virus Total, Malware Bazaar etc...)
- 2) Analyzing DNS queries (long subdomains or high volumes of requests to suspicious domains)
- 3) Creating honeypots (fake open systems/services – bait) to lure the attackers in and then scan what they use (what C2 server they try to connect to) and they can more effectively block it

Actions on Objectives (MOST DESTRUCTIVE PHASE)

The attacker, after establishing C2 connection, can execute their original goals, which range from data exfiltration to service disruption.

Attacker can: delete or corrupt data (to disrupt normal system operations)

financial theft (ransomware)

stealing sensitive file (= data exfiltration) (industrial/political espionage)

manipulating ICSs (Industrial Control Systems)

SOLUTION:

- 1) Data Loss Prevention (DLP) – backup and recovery plan
- 2) Network segmentation – isolation of critical systems from the rest of the company (DMZ)
- 3) Access controls and principle of least privilege – limit who can access sensitive systems and data
- 4) User activity monitoring

REAL WORLD EXAMPLE – DATA BREACH OF CARNIVAL CORPORATION

Source: (<https://www.bleepingcomputer.com/news/security/carnival-cruise-confirms-data-breach-affecting-nearly-6-million-people/>)

1) Reconnaissance

Attackers gather information about Carnival Corporation and its employees.

- Identify employee roles (especially IT / support / admins)
- Collect emails via LinkedIn, data leaks (a few already happened)
- Study internal structure across cruise brands

2) Weaponization

Preparation of the attack method

- Create social engineering lures (IT support reset requests, OAuth consent tricks....)
- Prepare phishing infrastructure of fake login portals
- Craft scripts for impersonation (internal IT / helpdesk / Microsoft)

3) Delivery

How the attack reaches the victim

- Phishing email or SMS pretending to be IT/security alert
- Vishing (phone call pretending to be IT support)

4) Exploitation

The user interaction leads to compromise

- Employee is tricked into entering credentials into a fake login page, sharing MFA codes etc...

Result is: Attacker gains valid session (no malware necessarily needed – pure identity compromise)

5) Installation

Establishing persistence or maintaining access

- Session cookies or access token stolen and reused
- OAuth application granted persistent access to email/SaaS

6) Command and Control (C2)

Attackers maintain control over compromised environment

- use of valid session tokens to access Microsoft 365 / internal portals
- No traditional malware C2 needed (this is „living off the cloud “)
- blends into normal traffic to avoid detection

7) Actions on Objectives

Data theft + extortion

- Extraction of names, emails, locations, loyalty status
- Downloading internal corporate documents
- Aggregation of data for extortion („pay ransom or we leak your customer's PII “)

Alternative Kill Chain (which is highly possible in this scenario)

Reconnaissance > Weaponization > Delivery > Exploitation > Actions on Objectives

- 1) Social-engineered an employee
- 2) Obtained access to a valid account
- 3) Accessed the relevant systems
- 4) Downloaded the data
- 5) Left

Minimal attack path by MITRE ATT&CK could be:

- 1) T1566 – Phishing / Social engineering
- 2) T1078 – Valid Accounts
- 3) T1528 – Steal Application Access Token
- 4) T1213 – Data from Information Repositories
- 5) T1020 – Automated Exfiltration / T1567 – Exfiltration to Cloud Storage

Persistence could not be confirmed from the available information. The threat actor may have conducted a smash-and-grab operation, using a socially engineered account to access and exfiltrate data without establishing long-term persistence in the environment.